

## CCCS 453 – Security Risk Management and Governance

## MODULE 7

## Assignment #4: GDPR

Al Labade, Ayman 261239044

Our company is submitting this notification to the competent supervisory authority under Article 33 of the General Data Protection Regulation (GDPR) in relation to a recent personal data breach.

**1. Nature of the personal data breach**

On February 24, 2026, an employee responding to customer requests for access to their records mistakenly attached the wrong files to outgoing emails, sending personal data of other customers to about one hundred recipients. Because the files were indexed incorrectly, each email included personal data belonging to other customers, resulting in an unauthorized disclosure of their information. This was a confidentiality incident only. The data were not deleted or lost.

**2. Categories and approximate number of data subjects and records**

The affected data subjects are individual customers of our company who requested access to their records. Our internal review shows that about one hundred customers are affected and that roughly one hundred personal data records were disclosed to unintended recipients. Each affected record contained: name and surname, email address, phone number, the last four digits of a credit card, and purchase history (e.g. dates and items purchased).

**3. Contact details of the Data Protection Officer**

Data Protection Officer: Ayman Al Labade

Email: ayman.allabade@mail.mcgill.ca

This is the main contact point for any questions regarding this notification.

**4. Likely consequences of the personal data breach**

The main risks for affected individuals are targeted phishing or social engineering attempts using accurate identity and purchase details, attempts at impersonation with service providers by combining contact details with the last four digits of the credit card, and loss of privacy and potential distress due to the shared purchase history with other customers.

**5. Measures taken or proposed to address the breach and mitigate its effects**

Immediately after discovering the incident, our company stopped using the faulty process, disabled the misconfigured indexing, and preserved relevant emails and system logs for investigation. We also contacted the recipients of the misdirected emails and asked them to delete the messages and attachments and not to retain, use, or further disclose the data. To prevent similar incidents in the future, we are now incorporating a mandatory double-check step (such as peer review or system confirmation) before sending emails with customer personal data. We are also strengthening technical controls, including data loss prevention (DLP) rules that flag or block mismatched attachments and recipients. Lastly, we are updating our procedures and providing focused training for staff who handle customer records.